המסלול האקדמי המכללה למינהל
מדעי המחשב

ת.ז הסטודנט:_____
מס' חדר:_____ מס' נבחן:_____

בחינה בקורס: מבוא לאבטחת סייבר
קוד קורס: 689156
תאריך הבחינה: 20/10/2024 שעת הבחינה: 09:00
שנה"ל: תשפ"ד סמסטר: קיץ מועד: ב'
מרצה: ד"ר מנחם ליבוביץ
משך הבחינה: 01:20 שעות

- מספר השאלות בשאלון: 10
- יש להשיב על כל השאלות
- משקל כל שאלה: 10 נקודות
- הבחינה ללא חומר עזר
- שימוש במחשבון כיס: כן
- מחברת טיוטה: לא
- בכל שאלה יש לסמן את התשובה הנכונה ביותר בדף הקידוד. **רק דף הקידוד ייבדק!**
- את התשובות יש לסמן **בעט שחור או כחול כהה בלבד, באופן ברור ומודגש. יש להקפיד על כתב יד קריא וברור**
- אין לסמן על דף הקידוד ו/או שאלון הבחינה במַדְגֵּשׁ (מַרְקֵר) זוהר
- **חל איסור לתלוש דפים משאלון הבחינה!**
- יש להחזיר את שאלון הבחינה, כולל נספחים (אם קיימים)
- בבחינה זו מתקיים נוהל הוצאת פתקים בשעות: 09:20, 09:50. לזכאי תוספת זמן גם בשעה 10:20

חשוב מאוד:
- בדף הקידוד יש לרשום ולקדד את מספר המבחן המופיע בראש הדף בצד ימין (מספר בן 3 ספרות)
- יש לרשום את מספר תעודת הזהות במקום המיועד בכתב יד ברור (כולל ספרת הביקורת)

בהצלחה!

בכל השאלות הבאות, התשובה הנכונה היא א

<u>שאלה מספר 1:</u>

להלן רשימה של סקריפטים המייצגים ביצוע של טרנזקציה בביטקוין (כל סקריפט כבר מכיל את השילוב של ה input script עם ה output script). רק סקריפט אחד הינו חוקי ותקני. סמנו אותו.

א. [Signature] [Public Key] DUP HASH160 [Key Hash] EQUALVERIFY CHECKSIG

ב. [Signature] [Public Key] DUP HASH160 [Key Hash] EQUALVERIFY

ג. [Public Key] [Signature] HASH160 DUP [Key Hash] EQUALVERIFY CHECKSIG

ד. CHECKSIG [Public Key] [Signature] HASH160 DUP [Key Hash] EQUALVERIFY

<u>שאלה מספר 2:</u>

אתר foo.com הוא רשת חברתית פשוטה, בה כל משתמש רשום, למשל בוב (Bob), יכול להעלות הודעה קצרה, למשל msg, ע"י מילוי ושליחת טופס ב"דף הבית" שלו (בכתובת foo.com/Bob); שליחת הטופס תבוצע ע"י בקשת GET לכתובת foo.com/Bob?m=msg. ההודעה תוצג בדף הבית של בוב וכן ב"קיר של בוב" בכתובת foo.com/Bob/wall, וגם בדפי הבית של ה"חברים" של בוב, למשל בדף /foo.com Alice. האתר משתמש ב"עוגיות" לזיהוי המשתמש, כדי למנוע למשל מתוקף (עם או בלי חשבון) להעלות הודעה תוך התחזות לבוב.

איזה מבין הטענות הבאות נכונה?

א. אם בוב יבקר באתר שבשליטת תוקף, התוקף יכול להעלות הודעות תוך התחזות לבוב

ב. השימוש המתואר בשאלה בעוגיות מבטיח שתוקף לא יוכל להעלות הודעות תוך התחזות לבוב

ג. השימוש המתואר בשאלה בבקשת GET מבטיח שתוקף לא יוכל להעלות הודעות תוך התחזות לבוב

ד. אם השרת היה משתמש ב blind sql התוקף לא היה יכול להעלות הודעות תוך התחזות לבוב

<u>שאלה מספר 3:</u>

אליס גלשה לאתר של בוב ב HTTPS, ונתון תוקף Man in the Middle נמצא בין אליס לאתר. נתון שהתוקף השיג את המפתחות הפרטיים של בוב המשמשים את בוב לתקשורת HTTPS ושבוב גילה שהמפתחות שלו הגיעו לידיו של התוקף.

איזה מהסעיפים הבאים <u>לא</u> יסייעו לעצירת התקפות אפשריות של התוקף?

א. Soft fail

ב. Certificate Revocation List (CRL)

ג. Online certificate status protocol (OCSP)

ד. CRLsets

<u>שאלה מספר 4:</u>

איזו מבין הטענות הבאות נכונה?

א. שרת Root CA חותם על המפתח הפומבי של intermediate CA

ב. ב TLS, לא משתמשים ב chain of trust

ג. לקוח הגולש לשרת foo.com מוודא את תקינות התעודה שקיבל מהשרת ע"י וידוא שהתעודה נחתמה באופן קריפטוגרפי חוקי ע"י foo.com

ד. שרת אינטרנט ניגש ל Root CA ומבקש ממנו לחתום על המפתח הפרטי של שרת האינטרנט

<u>שאלה מספר 5:</u>

איזו מבין הטענות הבאות <u>אינה</u> נכונה?

א. ב XSS מסוג DOM-based החולשה נמצאת בקוד שרץ בצד השרת

ב. אחת מהדרכים להגן מפני התקפת CSRF היא בעזרת anti CSRF token. הגנה זאת הינה שקופה עבור המשתמשים ולא מצריכה מהם התנהגות מיוחדת

ג. התקפת CSRF קלאסית, כפי שנלמדה בכיתה, בנויה על כך שהדפדפן מצרף עוגיות לבקשות

ד. בהתקפת CSRF השרת אינו יודע שהבקשה אינה באמת של הקורבן

<u>שאלה מספר 6:</u>

אליס ובוב רוצים לתקשר ביניהם בצורה מאובטחת, באופן כזה שאם x שולח הודעה, x לא יוכל לאחר מכן להתכחש שהוא שלח את ההודעה. בכדי להשיג תקשורת שכזאת, עליהם להשתמש ב:

א. חתימות דיגיטליות

ב. Message authentication codes (MAC)

ג. צופן קיסר

ד. CSRF

<u>שאלה מספר 7:</u>

איזו טענה <u>אינה</u> נכונה?

א. מנגנון ה Signed Certificate Timestamp (SCT) נועד לפתור בעיית פרטיות הקיימת במנגנון ה OCSP

ב. מנגנון ה Online Certificate Status Protocols (OCSP) ומנגנון ה Certificate Transparency פותרים בעיות שונות

ג. מנגנון Certificate Transparency ומנגנון Certificate Revocation List (CRL) פותרים בעיות שונות

ד. מנגנון Certificate Transparency בא לידי ביטוי ב certificates על ידי ערכי ה Signed Certificate Timestamp (SCT)

<u>שאלה מספר 8:</u>

נתון:

- **כתובת ה ip של אליס היא 192.168.0.1 וכתובת ה MAC שלה היא AA:AA:AA:AA:AA:AA**
- **כתובת ה ip של בוב היא 192.168.0.2 וכתובת ה MAC שלו היא BB:BB:BB:BB:BB:BB**
- **כתובת ה ip של התוקף היא 192.168.0.6 וכתובת ה MAC שלו היא 66:66:66:66:66:66**

לאחר שהתוקף ביצע בהצלחה התקפת ARP poisoning, כאשר אליס שולחת הודעה לבוב, לאיזה כתובת ip היא תשלח ולאיזה כתובת MAC?

א. לכתובת ip של 192.168.0.2 ולכתובת MAC של 66:66:66:66:66:66

ב. לכתובת ip של 192.168.0.6 ולכתובת MAC של 66:66:66:66:66:66

ג. לכתובת ip של 192.168.0.2 ולכתובת MAC של BB:BB:BB:BB:BB:BB

ד. לכתובת ip של 192.168.0.6 ולכתובת MAC של BB:BB:BB:BB:BB:BB

<u>שאלה מספר 9:</u>

אליס הצפינה בעזרת צופן DES (שגודל הבלוק שלו הוא 8 בתים) ושיטת הפעלה (mode of operation) של ECB, את הbytes של ה plaintext הבא:

ABCDEFGHABCDEFGH

עם מפתח ההצפנה שמורכב מהbytes של המחרוזת lemonlem. מה הייצוג ההקסדצימלי של ה bytes של ה ciphertext שיצא לה?

א. 437d7e60707604f3437d7e60707604f3

ב. 618142157df60e232e6fea24db009df9

ג. 00112233445566778899aabbccddeeff

ד. 2e6fea24db009df9ced6000330c42994

<u>שאלה מספר 10:</u>

הבטיחות של מנגנון החלפת המפתחות של דיפי-הלמן מתבססת על?

א. בעיית הלוגריתם הדיסקרטי

ב. צופן ויז׳נר

ג. אמון (trust)

ד. בעיית ה 51%

--- סוף המבחן ---